

به نام خدا



تمرین سوم امنیت داده و شبکه

نیم سال دوم ۱۴۰۴-۱۴۰۵

دانشکده مهندسی کامپیوتر

دانشگاه صنعتی شریف

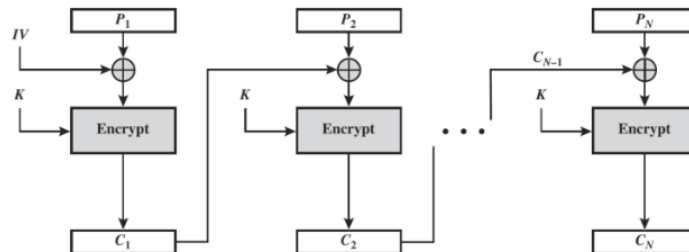
موضوع رمزنگاری

موعده تحویل ۱ تیر ۱۴۰۵، ساعت ۲۳:۵۹

طراحی تمرین توسط محمدعلی کاکاوند، محمدحسین چهکندی، علی اخگری

۱ رمزنگاری بلوکی در مود CBC

در این سؤال با مود CBC رمزنگاری بلوکی آشنا می‌شوید. شکل رمزکننده زیر را برای CBC در نظر بگیرید.



شکل ۱: مدار رمزکننده CBC

۱.۱ تأثیر Packet Loss بر رمزگشایی

فرض کنید در هنگام انتقال اطلاعات روی اینترنت، ۴ بلوک از cipher text به دلیل Packet Loss خراب می‌شوند. با توجه به مدار رمزگشایی، تعیین کنید حداقل و حداکثر چند بلوک در گیرنده به اشتباه آشکارسازی خواهد شد. استدلال خود را با ذکر نحوه انتشار خطا در مود CBC توضیح دهید.

۲ رمزنگاری نامتقارن: RSA و Diffie-Hellman

در این سؤال با دو پروتکل رمزنگاری نامتقارن RSA و Diffie-Hellman از طریق محاسبات عددی آشنا می‌شوید.

۱.۲ رمزنگاری RSA

پارامترهای سیستم به شرح زیر هستند:

$$p = 7, \quad q = 13, \quad e = 7, \quad M = 82$$

آ) کلید عمومی (n, e) و کلید خصوصی (n, d) را محاسبه کنید. برای یافتن d از الگوریتم اقلیدسی تعمیم‌یافته استفاده کنید و تمام مراحل را به صورت گام‌به‌گام نشان دهید.

ب) پیام M را با کلید عمومی رمز کنید و متن رمز شده C را به دست آورید.

ج) نشان دهید که با استفاده از کلید خصوصی (n, d) می‌توان C را رمزگشایی کرد و به پیام اصلی M رسید.

۲.۲ تبادل کلید Diffie-Hellman

پارامترهای عمومی به شرح زیر هستند:

$$q = 11, \quad \alpha = 2$$

که در آن q یک عدد اول و α یک ریشه اصلی است.

آ) اگر قسمت عمومی کلید آلیس $Y_A = 9$ باشد، کلید خصوصی X_A او چه عددی است؟ آیا برای یافتن X_A از روی Y_A در حالت کلی روش کارآمدی وجود دارد؟ توضیح دهید.

ب) اگر قسمت عمومی کلید باب $Y_B = 3$ باشد، کلید مشترک K_{AB} را محاسبه کنید. نشان دهید که هر دو طرف می‌توانند به طور مستقل به همین کلید برسند.

۳ امنیت ساختار پایه CBC-MAC

در این سؤال بررسی می‌کنیم که استفاده از ساختار پایه CBC-MAC برای پیام‌هایی با طول متغیر، چه پیامدهایی به دنبال دارد و چگونه می‌تواند به نقض امنیت منجر شود.

۱.۳ احراز هویت پیام‌های با طول مشخص توسط فرستنده

فرض کنید فرستنده و گیرنده از قبل روی طول پیام توافقی نکرده‌اند؛ به این معنا که فارغ از طول پیام m ، رابطه $\text{Vrfy}_k(m, t) = 1$ برقرار است اگر و تنها اگر $t = \text{Mac}_k(m)$ باشد. با این حال، فرستنده در سمت خود مراقب است و صرفاً پیام‌هایی به طول $2n$ را احراز هویت می‌کند.

- نشان دهید که در این شرایط، مهاجم می‌تواند یک تگ (برچسب) معتبر برای یک پیام دلخواه به طول $4n$ جعل کند. مسیر حمله و نحوه ساخت پیام جعلی را به صورت دقیق توضیح دهید.

۲.۳ محدودیت طول در سمت گیرنده

فرض کنید گیرنده فقط پیام‌های ۳-بلاک را می‌پذیرد. به عبارت دیگر، رابطه $\text{Vrfy}_k(m, t) = 1$ تنها در صورتی برقرار است که طول پیام m دقیقاً برابر با $3n$ باشد و همچنین معادله $t = \text{Mac}_k(m)$ صدق کند. اما از سوی دیگر، فرستنده انعطاف‌پذیرتر عمل کرده و پیام‌هایی با هر طولی که مضربی از بلوک n باشد را احراز هویت می‌کند.

- نشان دهید که مهاجم در این سناریو نیز می‌تواند یک تگ معتبر برای یک پیام جدید (که گیرنده آن را بپذیرد) جعل کند. روش مهاجم برای ترکیب یا تغییر بلوک‌ها جهت فریب گیرنده را شرح دهید.

۴ آسیب‌پذیری‌های توابع احراز هویت پیام (MAC) در بازی CryptoQuest

در بازی آنلاین CryptoQuest، بازیکنان می‌توانند با انجام مراحل، سکه طلا دریافت کنند. در پایان هر مرحله، بازی یک درخواست به سرور می‌فرستد تا سکه‌ها به حساب بازیکن اضافه شود. برای اینکه بازیکنان نتوانند درخواست‌ها را دستکاری کنند و به خودشان سکه بی‌نهایت بدهند، سرور روی هر درخواست یک «مهر تایید دیجیتال» یا MAC (مخفف Message Authentication Code) می‌زند.

این مهر با استفاده از یک تابع هش (Hash) ساخته می‌شود. تابع هش یک ماشین ریاضی است که هر متنی را می‌گیرد و یک رشته کاراکتر درهم‌ریخته (مثل یک اثر انگشت دیجیتال) تولید می‌کند. این فرآیند یک‌طرفه است؛ یعنی از روی اثر انگشت نمی‌توان متن اصلی را فهمید. برای امنیت، سرور یک کلید مخفی (K) دارد که فقط خودش آن را می‌داند و این کلید را با اطلاعات بازیکن ترکیب کرده و هش می‌گیرد.

طراحان این بازی در نسخه‌های مختلف، روش‌های متفاوتی برای ساخت این مهر امتحان کرده‌اند که هر کدام سوتی‌های عجیبی داشته است! شما در نقش یک هکر باید سیستم آن‌ها را دور بزنید.

۱.۴ نسخه اول

در نسخه اول، توسعه‌دهندگان مهر تایید را این‌گونه می‌ساختند: ابتدا کلید مخفی (K)، نام بازیکن ($player_id$) و تعداد سکه ($gold_amount$) را ساده و بدون هیچ فاصله‌ای به هم می‌چسباندند (علامت $||$ به معنی چسباندن متن‌هاست) و سپس از کل آن هش می‌گرفتند.

$$MAC = Hash(K || player_id || gold_amount)$$

فرض کنید شما اکانتی به نام eve1 ساخته‌اید و درخواستی برای دریافت 0 سکه می‌فرستید. سرور متن‌ها را می‌چسباند (می‌شود Keve10) و یک MAC معتبر به شما می‌دهد.

- شما چگونه می‌توانید از همین MAC (بدون نیاز به دانستن کلید مخفی) استفاده کنید تا برای اکانت اصلی خودتان که نامش eve است، 10 سکه طلا بگیرید؟

۲.۴ نسخه دوم

توسعه‌دهندگان متوجه اشتباهشان شدند. آن‌ها برای جدا کردن کلمات، علامت دو نقطه (:) را اضافه کردند. همچنین برای «امنیت بیشتر»، تصمیم گرفتند به جای چسباندن کلید، از عملگر ریاضی XOR (با نماد $\oplus$) استفاده کنند. فرمول جدید آن‌ها:

$$MAC = Hash(K) \oplus Hash(player_id || ":" || gold_amount)$$

شما نام کاربری تان eve است و درخواست دریافت 5 سکه را شنود کرده‌اید و MAC معتبر آن را در دست دارید.

- با دانستن نحوه کار این فرمول، چگونه می‌توانید یک درخواست کاملاً معتبر برای دریافت 9999 سکه جعل کنید، بدون اینکه کلید مخفی سرور را بدانید؟

۳.۴ نسخه سوم

توسعه‌دهندگان در نهایت تسلیم شدند و از یک استاندارد بی‌نقص استفاده کردند. برنامه‌نویس، کد بررسی و مقایسه مهرها را در سرور به این شکل نوشته است:

```

۱ def is_mac_valid(user_mac, server_mac):
۲     if len(user_mac) != len(server_mac):

```

```
۳     return False
۴
۵     for i in range(len(server_mac)):
۶         if user_mac[i] != server_mac[i]:
۷             return False
۸     return True
```

- با دقت در کد بالا، سرور چگونه به صورت ناخواسته به هکر کمک می کند تا حرف به حرف *MAC* صحیح را حدس بزند؟ هکر برای استخراج کامل مُهر تایید چه روندی را باید طی کند؟

۴.۴ راه حل نهایی

اگر شما به جای توسعه دهندگان این بازی بودید:

۱. چه ساختار استandar دی را به جای روش های ابداعی نسخه های ۱ و ۲ برای ساخت این مُهر تایید استفاده می کردید و ایده اصلی آن چیست؟
۲. برای رفع مشکل امنیتی در نسخه ۳، مقایسه دو رشته متنی باید به چه شکلی انجام شود؟

۵ ترکیب محرمانگی و صحت، و محدوده پوشش MAC

۱.۵ روش‌های ترکیب MAC و رمزنگاری

یک پروتکل شبکه نیازمند برقراری توأمان محرمانگی (Confidentiality) و صحت پیام (Integrity) است. طراحان دو رویکرد زیر را در نظر گرفته‌اند:

- روش اول (MAC-then-Encrypt): ابتدا محاسبه MAC و سپس رمزنگاری.

- روش دوم (Encrypt-then-MAC): ابتدا رمزنگاری و سپس محاسبه MAC .

با توجه به این دو رویکرد، به موارد زیر پاسخ دهید:

۱. هر دو روش را بر اساس عملیاتی که روی متن اصلی (Plaintext) و متن رمز شده (Ciphertext) انجام می‌شود، شرح دهید.

۲. در علم رمزنگاری نوین، عموماً کدام روش توصیه می‌شود؟ دلیل آن را به صورت سطح بالا و خلاصه بیان کنید.

۳. یک سناریوی حمله (حتی به صورت فرضی) ارائه دهید که نشان دهد چرا ترتیب این عملیات اهمیت دارد و انتخاب روش اشتباه می‌تواند منجر به نقض امنیت شود.

۲.۵ محدوده اعمال MAC روی بسته‌های شبکه

در یک پروتکل شبکه، هر بسته ارسالی دارای دو بخش است:

- سرآیند یا هدر h (که رمزنگاری نشده است و برای مسیریابی استفاده می‌شود).

- بارمفید یا Payload با نماد p (که رمزنگاری شده است).

طراح سیستم قصد دارد برای تضمین صحت از MAC استفاده کند، اما مطمئن نیست که کدام یک از حالت‌های زیر را انتخاب کند:

- اعمال MAC فقط روی بارمفید p .

- اعمال MAC روی ترکیب هدر و بارمفید (h, p) .

با توجه به این سناریو، به سوالات زیر پاسخ دهید:

۱. کدام انتخاب امنیت بیشتری را فراهم می‌کند؟

۲. حمله‌ای را توصیف کنید که اگر هدر شبکه (h) در محاسبه MAC لحاظ نشود، امکان‌پذیر خواهد بود.

۳. با وجود خطرات احتمالی، چرا برخی پروتکل‌ها ممکن است همچنان فیلدهای خاصی (مانند بخش‌هایی از هدر) را خارج از محاسبه MAC رها کنند؟

۶ استفاده مجدد از Nonce در DSS

یک شرکت مالی الگوریتم امضای DSS را برای احراز هویت تراکنش‌ها در سامانه خود پیاده‌سازی کرده است. برای بهبود عملکرد و سرعت بیش‌تر در دستگاه‌های دارای محدودیت منابع، این پیاده‌سازی گاهی اوقات به جای تولید یک عدد تصادفی k برای هر پیام، از یک عدد یکسان برای چندین امضا مجدداً استفاده می‌کند. در طول یک ارزیابی امنیتی، دو امضای تولید شده توسط یک کاربر شنود شد. هر دو امضا شامل مقدار یکسانی برای r هستند که نشان می‌دهد از یک نانس یکسان k مجدداً استفاده شده است.

پارامترهای دامنه DSS عبارتند از $p = 23$ ، $q = 11$ و $g = 2$. کلید عمومی آلیس $y = 18$ است. کلید خصوصی او (x) نامشخص است.

داده‌های شنود شده به شرح زیر هستند:

• امضای اول: $H(M_1) = 4$ و $(r, s_1) = (8, 10)$

• امضای دوم: $H(M_2) = 5$ و $(r, s_2) = (8, 3)$

در الگوریتم DSS، مولفه امضای (s) به صورت زیر محاسبه می‌شود:

$$s = k^{-1}(H(M) + xr) \pmod{q}$$

که در آن k عدد تصادفی یک‌بار مصرف، x کلید خصوصی امضاکننده، $H(M)$ چکیده پیام، و r و s مقادیر امضا هستند.

۱.۶ استخراج فرمول‌های بازیابی

با شروع از معادله امضای DSS:

(آ) فرمولی صریح برای بازیابی k به دست آورید.

(ب) فرمولی صریح برای بازیابی کلید خصوصی به دست آورید.

۲.۶ محاسبه کلید خصوصی

با استفاده از امضاهای شنود شده و فرمول‌های استخراج‌شده:

(آ) مقدار k را محاسبه کنید.

(ب) کلید خصوصی آلیس x را محاسبه کنید.

(ج) کلید عمومی را از روی مقدار بدست آمده تولید کنید تا از صحت محاسبات خود مطمئن شوید.

۳.۶ مکانیزم استاندارد جلوگیری از استفاده مجدد Nonce

پیاده‌سازی‌های مدرن DSS دیگر صرفاً به تولید نانس تصادفی متکی نیستند.

(آ) مکانیزم استاندارد صنعتی که برای جلوگیری از استفاده مجدد نانس به کار می‌رود را شناسایی کنید (RFC مربوطه را پیدا کنید).

(ب) توضیح دهید که این مکانیزم چگونه نانس‌ها را تولید می‌کند.

(ج) بیان کنید که چرا این روش، خطرات مرتبط با تولیدکننده‌های اعداد تصادفی ضعیف یا معیوب را از بین می‌برد.

۷ امنیت در معماری PKI

یک سازمان خصوصی درمانی برای ایمن سازی داده های حساس و خدمات حیاتی خود از یک زیرساخت کلید عمومی (PKI) دو لایه بهره می برد. اجزای این سامانه و نحوه تعامل موجودیت های مختلف به شرح زیر است:

- **مرجع صدور گواهی ریشه (Root CA):** این مرجع به صورت آفلاین (Offline) نگهداری شده و کلید خصوصی آن تنها برای امضا و صدور گواهی مراجع صدور میانی کاربرد دارد.

- **مرجع صدور میانی کاربران و تجهیزات (User & Device Intermediate CA):** این مرجع آنلاین وظیفه صدور گواهی های نهایی را برای اعضای سازمان و دستگاه ها بر عهده دارد:

- **کارکنان (پزشکان و پرستاران):** از گواهی های احراز هویت موجود روی کارت های هوشمند شخصی برای ورود به سیستم ها و از گواهی های S/MIME جهت رمزنگاری و امضای دیجیتال ایمیل های حاوی اطلاعات بیماران استفاده می کنند.

- **دستگاه های اینترنت اشیا پزشکی:** دارای گواهی های تعبیه شده در سخت افزار جهت برقراری ارتباطات امن بر پایه احراز هویت متقابل با سرورها بر بستر TLS هستند.

- **مرجع صدور میانی زیرساخت (Infrastructure Intermediate CA):** این مرجع آنلاین به طور اختصاصی وظیفه صدور گواهی برای سرورها و تجهیزات هسته شبکه را بر عهده دارد:

- **سرورهای پرونده سلامت الکترونیک (EHR):** گواهی های TLS/SSL سرور برای ایمن سازی دسترسی وب و تبادل داده های ساختاریافته پزشکی.

- **درگاه های شبکه خصوصی مجازی (VPN Gateways):** گواهی های دستگاهی جهت اعتبارسنجی و برقراری تونل های امن دسترسی از راه دور برای کارکنان دورکار.

- **مراجع ثبت نام (RA):** مرجعی که وظیفه احراز هویت فیزیکی کلاینت ها یا بررسی شناسه دستگاه ها و تایید درخواست های صدور گواهی (CSR) را پیش از ارسال به مراجع صدور میانی انجام می دهند.

- **نقاط توزیع CRL (CDP) و پاسخ دهنده های OCSP:** مراجع آنلاین و آفلاینی که برای ارزیابی وضعیت اعتبار گواهی ها در هر لحظه توسط سرویس ها و دستگاه ها استعلام می شوند.

یک باج افزار موفق شده است به سرور مرجع صدور میانی کاربران و تجهیزات (User & Device Intermediate CA) نفوذ کند. بازرسان امنیت مشکوک هستند که کلید خصوصی این CA میانی فاش شده است. به دنبال این حادثه، چندین بیمارستان با خطاهای اعتبارسنجی گواهی در تجهیزات IoT و اختلال در ورود کاربران مواجه شده اند، اما ارتباط با سرورهای اصلی وب و سامانه EHR بدون مشکل و خطای امنیتی برقرار است.

۱.۷ تحلیل دامنه نفوذ

با فرض اینکه مهاجمان به کلید خصوصی User & Device Intermediate CA دست یافته اند، به سوالات زیر پاسخ دهید:

(آ) آیا مهاجم می تواند یک گواهی معتبر برای یک سرور جعلی EHR جعل کند تا حمله مرد میانی (MitM) انجام دهد؟ مشخص کنید مهاجم چه نوع گواهی های جعلی را می تواند صادر کند.

(ب) تأثیر این نفوذ را بر ویژگی های امنیتی زیر، صرفاً در حوزه عملکرد کاربران (ایمیل ها و احراز هویت) و دستگاه های پزشکی (IoT) ارزیابی کرده و نحوه آسیب دیدن هر یک را با ذکر مثال توضیح دهید:

- صحت (Integrity)

- محرمانگی (Confidentiality)

- احراز هویت (Authentication)
- عدم انکار (Non-repudiation)

ج) با توجه به ساختار سلسله مراتب مراجع صدور (CA Hierarchy)، مشخص کنید که آیا نیاز به باطل کردن گواهی Root CA یا گواهی های صادر شده توسط Infrastructure Intermediate CA وجود دارد یا خیر؟ استدلال خود را بیان کنید.

۲.۷ ابطال گواهی های جعل شده

سازمان ناچار است بلافاصله اعتماد به تمام گواهی های جعل شده توسط CA میانی را سلب کند.

آ) در این سناریو با توجه به وجود تعداد بسیار زیادی از دستگاه های IoT و کلاینت های کاربری، چالش ها و محدودیت های عملیاتی استفاده از لیست ابطال گواهی (CRL) را از نظر حجم فایل، پهنای باند شبکه و تاخیر (Latency) بررسی کنید.

ب) استفاده از پروتکل وضعیت آنلاین گواهی (OCSP) چگونه می تواند محدودیت های CRL را در این شبکه درمانی پوشش دهد؟ نقاط ضعف احتمالی خود OCSP را در هنگام مواجهه با حجم عظیم درخواست های همزمان از سوی تجهیزات پزشکی بیان کنید.

۳.۷ بهبودهای پیشنهادی معماری PKI

حداقل سه بهبود ساختاری، فنی یا سیاست گذاری پیشنهاد دهید که اعمال آن ها در معماری جدید PKI این سازمان بتواند احتمال وقوع چنین نفوذهایی را کاهش داده یا در صورت وقوع مجدد، اثرات مخرب آن را به حداقل برساند.